RISKMANDATE + SHARNESS

Secure your agents. Then insure them.

Give agents access. Not free rein.

Open-source technology. Enterprise-grade operations. An open stack that writes down what each agent may do, enforces it outside the agent, and proves it, in the customer’s own environment.

THE PROBLEM

Agents act with access nobody bounded.

The grant

What can it actually reach?

Credentials, data, tools and systems, measured on the agent itself.

The mandate

What was it authorised to do?

Rarely written down, and never by the people who carry the risk.

The barrier

What actually stops it?

A prompt is not a security boundary. Most rules are prose the agent reads.

The gap between the grant and the mandate is exposure nobody accepted.

WHY NOW

Three clocks started at once.

THE INCIDENTS

A contractor’s coding agent, with the person’s own login, ran on a Pentagon network for about two months.

WIRED, 29 Oct 2026, unnamed sources; the company disputes it.

THE INSURERS

Carriers are filing to exclude AI from cover.

Cover will turn on evidence of controls, not a questionnaire.

THE BUDGET

$2.8B → $4.8B

Securing-AI spending, 2026 to 2027 (Gartner, 26 Aug 2026). Not our TAM.

And OWASP now publishes a Top 10 for agentic applications (2026).

THE SOLUTION

Describe. Enforce. Prove. Insure.

Describe

The Agent Behaviour Policy: reach, mandate, gap, and the barrier on every row.

RiskMandate

Enforce

The policy becomes boundaries the kernel holds, outside the agent, before it starts.

SHarness

Prove

What held and what happened, signed and kept in the customer's own vault.

sgit + PKI

Insure

A record an underwriter can price, row by row: the destination.

Insurability Index

RiskMandate writes the mandate and never sits in the request path. SHarness enforces it. The agent cannot rewrite its own guardrails.

THE STACK

One open stack, from policy to proof.

Agent Behaviour Policy	The open specification: what one agent can reach, what it may do, the gap, the barrier.
SHarness	The secure harness: each process the agent starts runs under a policy the kernel enforces.
sgit vaults	Encrypted, versioned evidence and builds; the customer holds the keys.
A key for every session	Each agent session makes its own key; a person vouches for it with an end date (pki.sgit.ai).

All of it runs in the customer’s environment. Our cloud is optional.

THE WEDGE

Privileged coding and DevOps agents first.

THE AGENT TRIES

To read a credential and send it to a site it has never been told about.

THE POLICY SAYS

No credentials file in reach; hosts only on the allow-list.

THE KERNEL REFUSES

SHarness holds it below the agent, and the attempt is recorded as evidence.

One agent, its own session key, never a person’s login. The same policy also covers the business-app agents in our library: Gmail, Microsoft 365, CRM, HR.

WE RUN IT OURSELVES

Our own agent teams work under it every day.

31
agent sessions, each with its own key, for one person, in two days

9
agents built a conference talk in one day, each under a written policy

1 in 11
rules on our writing agent was a real Boundary, before SHarness

294
pages of a book drafted overnight by an agent team, every number with an id

Our own agents’ behaviour policies are published on riskmandate.ai/team. We sell what we use.

WHY OPEN SOURCE WINS

Open the technology. Sell the fit.

No black box

A security control nobody can read is not one a CISO, an auditor or an insurer should trust.

Less code

A customer who uses 5 features of 50 should not run the other 45. We customise it down, and every feature removed is attack surface removed.

The maker certifies

Each customised build is hashed and licensed to the customer with our key. Proprietary to them; the base stays open.

Open forever: the policy format, the enforcement, local evidence, self-hosting. [Copyright structure to state: no CLA, or a foundation.]

WHERE IT RUNS

In the customer’s environment. Their keys, their data.

THE REAL SALE

Their environment

The stack runs where their agents run: their machines, their cloud accounts, their CI. Nothing leaves.

OR MANAGED

Still theirs

We operate it for them in a dedicated account they own.

ENTRY LEVEL

Our cloud

Shared tenant, lower price, for smaller teams.

Every paid tier includes fleet governance and visibility, the customer’s integrations, an SLA, assurance and support. It grows with the agents and workflows covered.

The zero-knowledge design means even our cloud only ever holds ciphertext.

BUSINESS MODEL

A ladder from free to customised.

Open source

Free

The whole stack, self-hosted.

Self-serve policy

£10–£1,500

Live in our store today, up to a policy signed by a professional.

Customised

$10K a year

About $1K a month: one fleet's policies and harness, fitted.

Customised

$50K a year

About $5K a month: several workflows and their integrations.

Customised

$100K+ a year

About $10K a month: the enterprise build, certified, in their environment, with support.

WHERE IT GOES

Land in security. Arrive at insurance.

TODAY'S BUYER

1. Secure

CISOs and AI platform leads securing privileged coding and infrastructure agents.

Customised subscriptions

THE PLATFORM

2. Authorise

Signed mandates and delegations across organisations: a licence to operate for every agent.

Platform usage, per agent

THE DESTINATION

3. Insure

Enforced controls an underwriter can price, row by row: agents become insurable.

Assurance and insurance services

Revenue grows with every agent covered. The large outcome is the network layer: the mandates, keys and evidence every agent is checked against.

POSITIONING

Everyone owns one piece. We connect the loop.

Identity and IAM

Who the agent is, and the grant.

Not what it is for.

Posture and monitoring

What happened, after it happened.

Not what stops it.

GRC

What was promised, on paper.

Not whether it held.

Insurers

What the risk costs.

Without evidence to price it.

RiskMandate + SHarness The mandate, enforced outside the agent, proved and priced: the record each of them is missing.

Complementary to GRC, identity and posture tools, not a replacement. No proprietary safety features; no maze of tiers.

GO TO MARKET

Developers install it. Security buys the fit.

01	**Open-source adoption**	A developer runs SHarness and an open policy on a live agent. **Outcome: a working local control**
02	**Paid pilot**	Security protects one privileged agent workflow, in their environment. **Outcome: measured prevented actions**
03	**Customised contract**	The fleet’s policies, harness and evidence, fitted and certified. **Outcome: recurring annual revenue**
04	**The insurer**	The evidence record goes to the underwriter at renewal. **Outcome: cover, and a reason to expand**

Initial customers: AI platform leads and CISOs at enterprises deploying coding and infrastructure agents.

WHAT IS REAL TODAY

The open foundations run. The integrated product is next.

PUBLIC TODAY

- The Agent Behaviour Policy spec and its template library
- A store selling policies, £10 to £1,500
- SHarness 0.2.0, Apache 2.0, with kernel locks
- sgit vaults and a key for every agent session
- Our own teams running on all of it

BUILD NEXT

- The launcher that binds an agent end to end
- Policy compiled to process policy (ABP to PBP)
- Connectors for enterprise identity and CI
- The Insurability Index
- Independent testing and paid pilots

TEAM

Cyber insurance meets security engineering.

Nimay Parekh

Co-founder and CEO

Built cyber-insurance and supply-chain risk products at SecurityScorecard. Senior partnerships and product leadership in enterprise software. INSEAD MBA; White House innovation fellowship.

Dinis Cruz

Co-founder

Long-time application-security and OWASP leader. Former CISO, Holland & Barrett; Chief Scientist, Glasswall; founder, The Cyber Boardroom. Builder of the Agent Behaviour Policy, SHarness and sgit.

RISKMANDATE + SHARNESS

Every agent needs permission to act.

We make it explicit, enforced and provable. Then insurable.

Seeking design partners and seed investors.

riskmandate.ai · sharness.ai · sgit.ai

SOURCES

Research notes and assumptions

What	Where
Company, founders, policy, pricing	riskmandate.ai, /about.html, /pricing.html
SHarness release and status	sharness.ai; newsroom.sgit.ai/articles/introducing-sharness.html
The contractor’s agent at the Pentagon	WIRED, 29 Oct 2026, read through its coverage; newsroom.sgit.ai/articles/the-contractors-agent-and-three-policies.html
Our teams’ numbers (31 keys, 9 agents, 294 pages)	the talk’s, book’s and cold read’s repositories on GitHub (SGit-AI)
Customised open source	newsroom.sgit.ai/articles/selling-less-code.html; open-source.sgit.ai
Insuring agents row by row	newsroom.sgit.ai/articles/a-payout-for-every-row.html
Securing-AI spending	Gartner press release, 26 Aug 2026
Agentic risk guidance	OWASP Top 10 for Agentic Applications, 2026

Forward-looking statements (integrations, packaging, pilots, prices above self-serve, market expansion) are hypotheses, not outcomes.